

Ethical Hacker



PART 1

Introduction to Ethical Hacking.

Assistant Teacher: Mubarak Altamimi.

Fall in love with the process, and the results will come.
~ Eric Thomas



Introduction to the Course

► Contact me on

eng.mobaraktamimi@yahoo.com

► Textbooks

- Graham, D. G. (2021). Ethical Hacking: A Hands-on Introduction to Breaking In. No Starch Press.
- O'Leary, M. Cyber Operations: Building, Defending, and Attacking Modern Computer Networks by Mike O'Leary (2015-10-25).

Introduction to the Course

▶ Grading

- Midterm Exam: 30%
- Final Exam: 50%

▶ 20%

- Homework
- Project

WELCOME TO EH TRAINING



Module 01

Introduction to Ethical Hacking



What is covered in Module 1?



In this module, we'll learn about keeping information safe, different ways hackers work (hacking methodologies and frameworks), and important hacking ideas.



This module also covers what you need to become an ethical hacker, as well as what you can and can't do in ethical hacking.



We'll talk about different ways to keep information safe, like using security controls such as Information Assurance, Defense-in-Depth, risk management, cyber threat intelligence, threat modeling, incident management, AI/ML, and more.



Later we will talk about different rules and guidelines that help keep information safe i.e. information security laws and standards.



Elements of Information Security

Information security is a state of well-being of information and infrastructure in which the possibility of **theft, tampering,** and **disruption of information and services** is low or tolerable

Confidentiality

Assurance that the information is accessible only to those **authorized to have access**

Integrity

The **trustworthiness of data or resources** in terms of preventing improper or unauthorized changes

Availability

Assurance that the systems responsible for delivering, storing, and processing information are accessible when **required by the authorized users**

Authenticity

Refers to the characteristic of a communication, document, or any data that ensures the **quality of being genuine**

Non-Repudiation

A **guarantee** that the sender of a message cannot later deny having sent the message and that the recipient cannot deny having received the message

What Security Controls shall we implement to ensure Confidentiality?

To ensure **Confidentiality**, we implement **strong access controls**, **encryption methods**, and **data classification**. These measures limit unauthorized access and protect sensitive information from being disclosed.

Access control is like having a key to your house; it decides who can enter and who can't, ensuring only the right people get in.



Encryption methods are like secret codes that make your messages unreadable to anyone except the person who has the special key to decode them, so your information stays safe and private.



Data classification is like sorting your secrets into three boxes: 'Public' for things everyone can see (like a birthday invitation), 'Internal' for things only people inside your family can see (like family photos), and 'Confidential' for things that nobody should see except you (like your diary).



What Security Controls shall we implement to ensure Integrity?

To ensure **Integrity**, we put in place measures like **data validation**, **checksums**, and **digital signatures**. These steps help prevent unauthorized changes, ensuring that data remains accurate and trustworthy.

Data validation is like double-checking that the information you receive, like a password or a form you fill out online, is correct and not something fake or harmful.



Checksums are like a special code attached to a file or message that helps you confirm it hasn't been tampered with during transmission, much like a seal on a package ensuring it hasn't been opened before it reaches you.

Hash sum

DFCD3454 BBEA788A
751A696C 24D97009
CA992D17

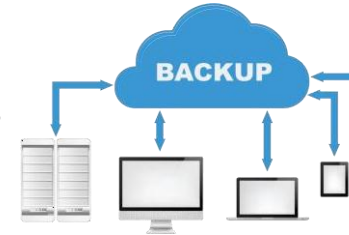
Digital signatures are like a unique, electronic 'stamp' on a document or message that proves it was created by a specific person or entity, just like a handwritten signature on a paper contract.



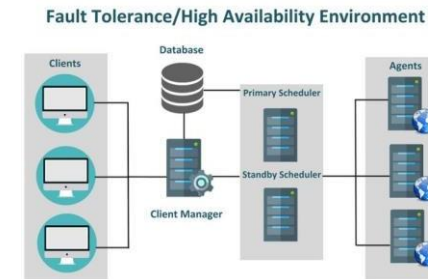
What Security Controls shall we implement to ensure Availability?

To ensure **Availability**, we take several steps. This includes setting up **backup systems**, designing **fault-tolerant systems**, **regularly creating backups of data**, and having **strong disaster recovery plans**. All of these measures help ensure that our systems, networks, and data are always accessible, minimizing any downtime or disruptions to our operations.

Backup systems are like spare copies of your important files or data stored in a safe place, so if something goes wrong with the original, you can easily restore it, similar to having spare keys in case you lose the original.



Fault-tolerant systems are like cars designed to keep running smoothly even if one part breaks, ensuring your journey continues without interruptions, much like having a spare tire in case one goes flat.



Strong disaster recovery plans are like emergency kits that help a business or organization quickly recover and continue functioning after unexpected events, such as a fire or a server crash, just like having a plan and supplies in case of a natural disaster like a hurricane.



What Security Controls shall we implement to ensure Authenticity?

To ensure **Authenticity**, we use robust authentication methods like **multi-factor authentication** and **digital certificates**. These methods help verify the identities of users, systems, and entities, ensuring that interactions and data exchanges are genuine and trustworthy.

Multi-factor authentication is like having two locks on your front door: you need both your regular key (password) and a special code from your phone (like a text message or app) to get in, making it much harder for someone to break in even if they know your password.

Multi factor authentication



Digital certificates are like ID cards for websites, proving they are who they claim to be, just as a driver's license proves your identity.

Digital Certificate



What Security Controls shall we implement to ensure Non-repudiation?

To ensure **Non-repudiation**, we employ tools like **digital signatures**, **audit trails**, and **secure logging**. These tools offer evidence and assurance about the integrity and source of transactions, making it impossible for someone to deny their involvement in a specific action.

Digital signatures are like a virtual 'seal' on an electronic document, verifying its authenticity, similar to a handwritten signature on a paper contract.



Audit trails are like a detailed history log of actions taken on a computer or system, similar to a security camera recording everything that happens in a store.



Secure logging is like a secret diary where every important event on a computer or system is recorded, so if there's a problem or a security breach, you can go back and see what happened, similar to keeping a journal of your daily activities.



Motives, Goals and Objectives of Information Security Attacks

Attacks = Motive (Goal) + Method + Vulnerability

- A motive originates out of the notion that the **target system stores or processes** something valuable, and this leads to the threat of an attack on the system
- Attackers try various tools and attack techniques to **exploit vulnerabilities** in a computer system or its security policy and controls in order to fulfil their motives

Motives behind information security attacks

- Disrupting business continuity
- Stealing information and manipulating data
- Creating fear and chaos by disrupting critical infrastructures
- Causing financial loss to the target
- Propagating religious or political beliefs
- Achieving a state's military objectives
- Damaging the reputation of the target
- Taking revenge
- Demanding ransom

Classification of Attacks

Passive Attacks

- Passive attacks do not tamper with the data and involve intercepting and **monitoring network traffic** and data flow on the target network
- Examples include sniffing and eavesdropping

Active Attacks

- Active attacks tamper with the data in transit or **disrupt the communication** or services between the systems to bypass or break into secured systems
- Examples include DoS, Man-in-the-Middle, session hijacking, and SQL injection

Close-in Attacks

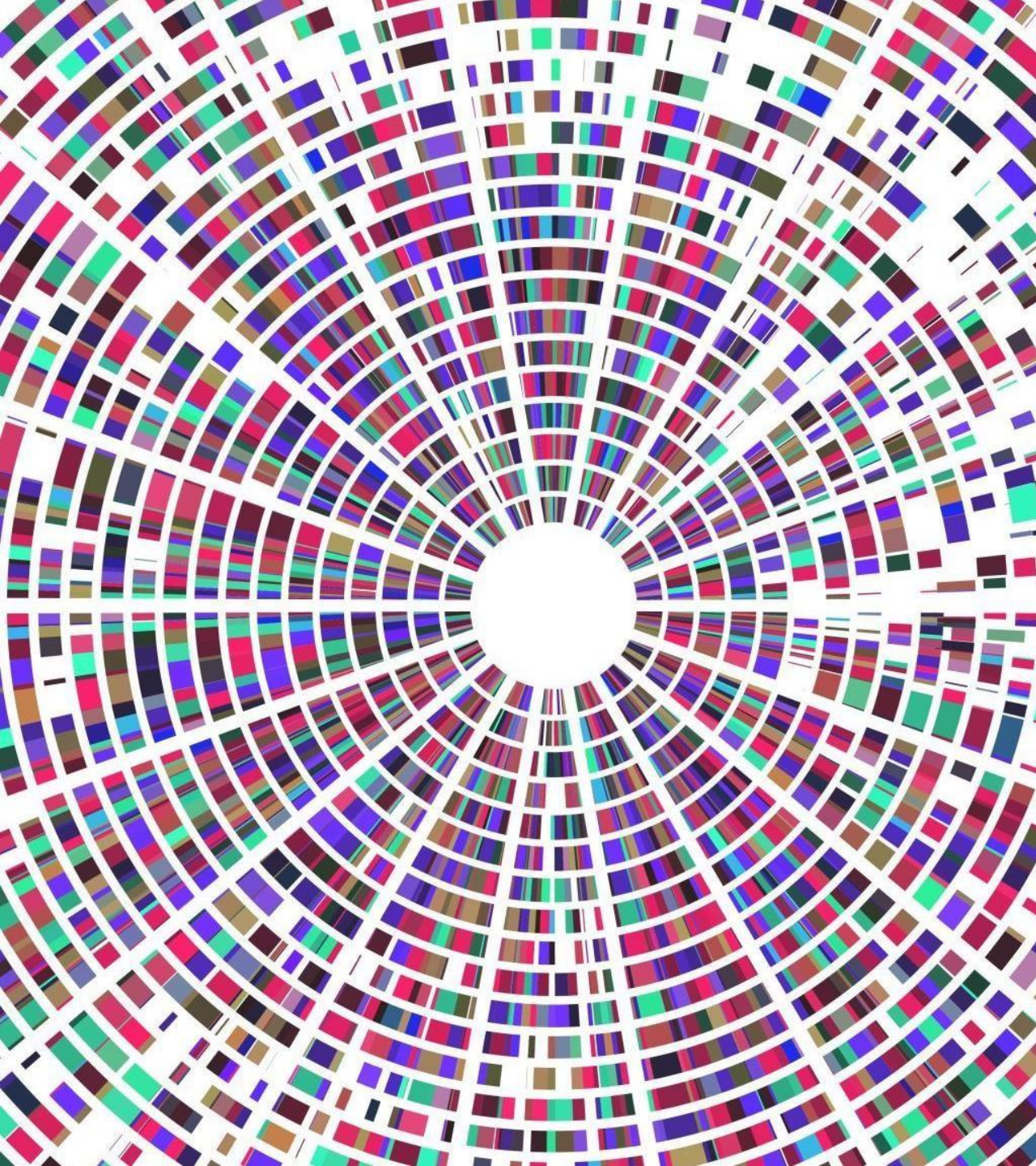
- Close-in attacks are performed when the attacker is in close physical proximity with the target system or network in order to gather, modify, or **disrupt access** to information
- Examples include social engineering such as eavesdropping, shoulder surfing, and dumpster diving

Insider Attacks

- Insider attacks involve using privileged access to **violate rules** or intentionally cause a threat to the organization's information or information systems
- Examples include theft of physical devices and planting keyloggers, backdoors, and malware

Distribution Attacks

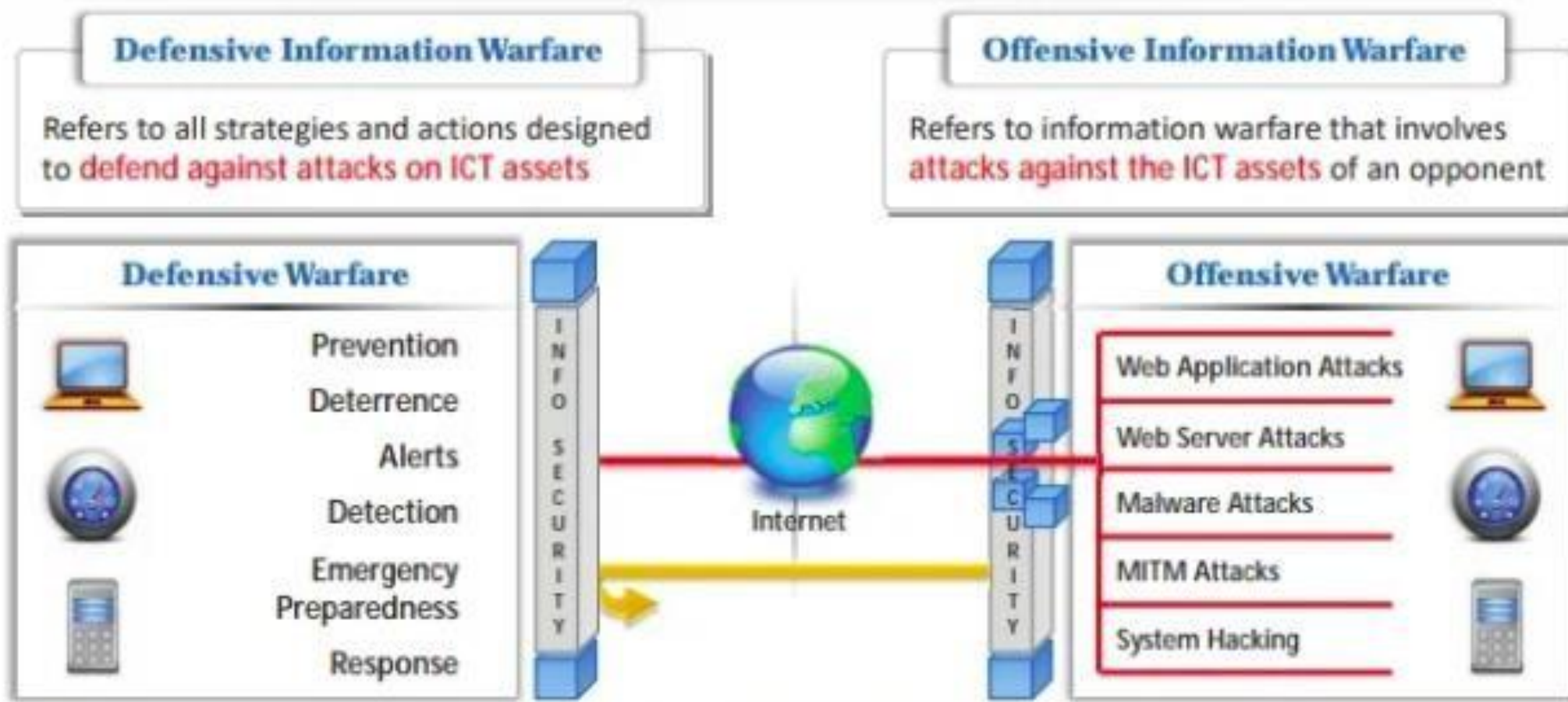
- Distribution attacks occur when attackers **tamper with hardware** or **software** prior to installation
- Attackers tamper with the hardware or software at its source or in transit

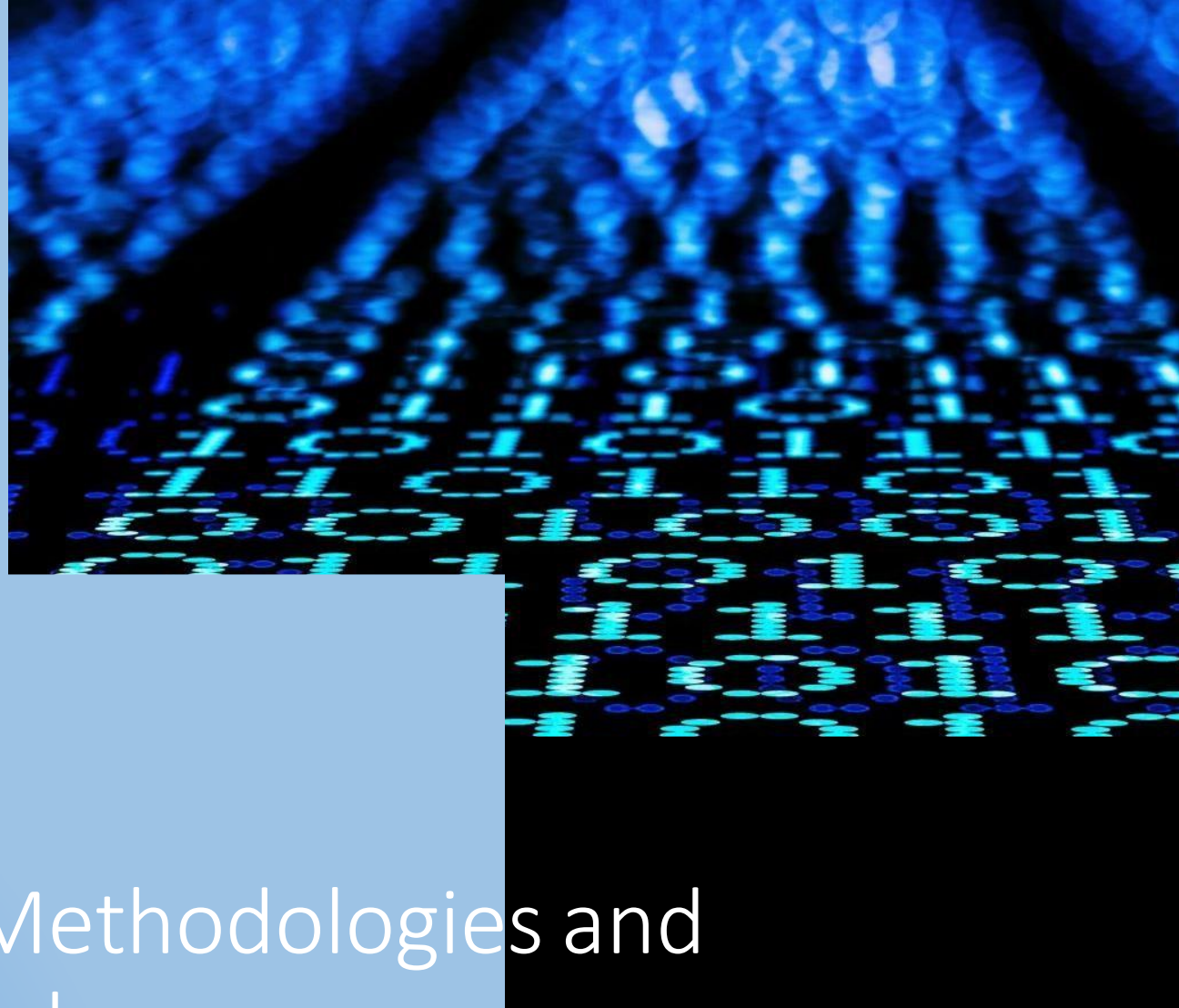


Information Warfare:

- **Information warfare refers to the strategic use of information and communication technologies (ICT) to gain an advantage over adversaries, influencing their perceptions, decisions, and actions.**

- The term information warfare or InfoWar refers to the **use of information and communication technologies (ICT)** to gain competitive advantages over an opponent

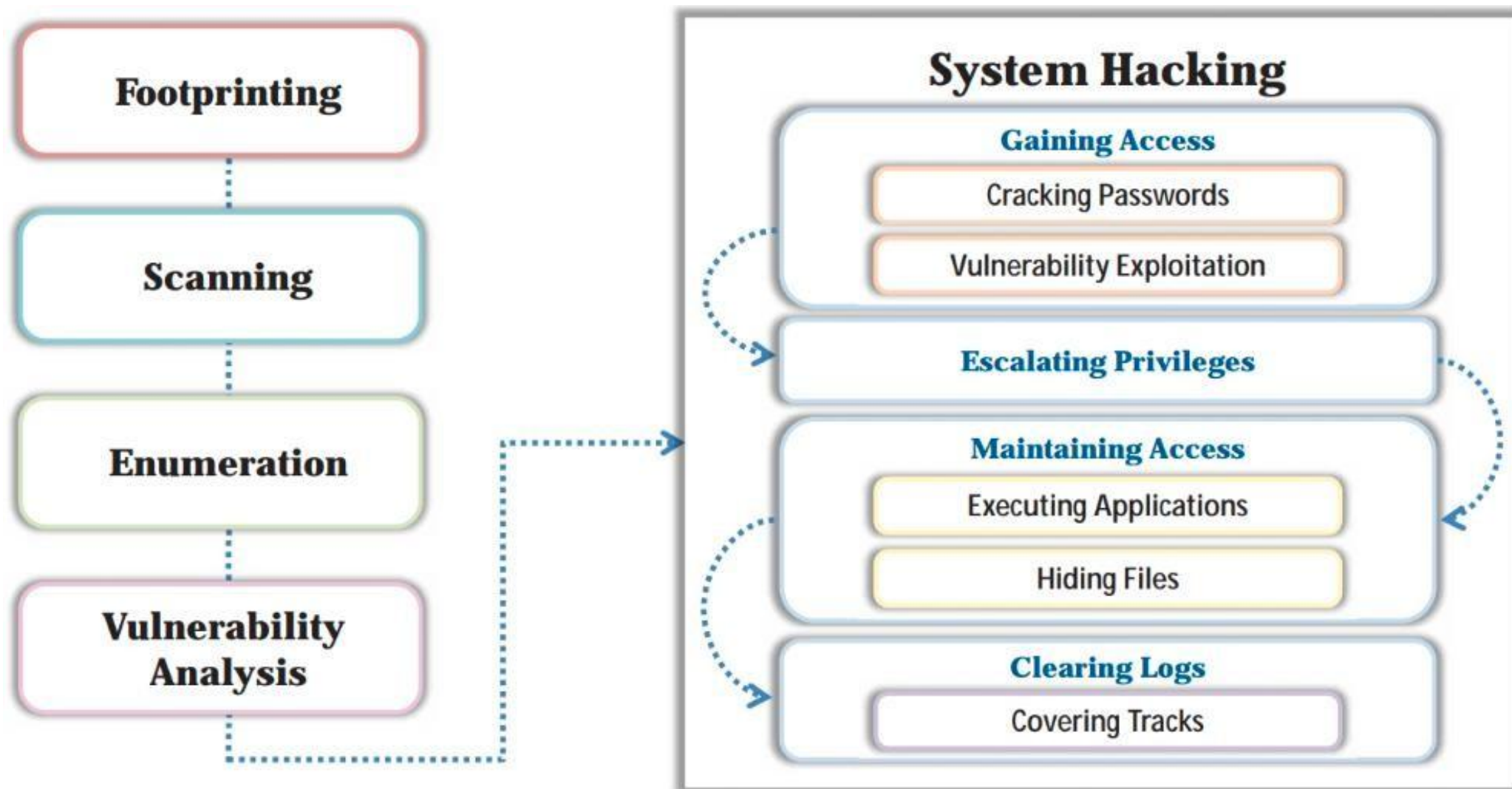




Hacking Methodologies and Frameworks

CEH Hacking Methodology (CHM):

The CEH Hacking Methodology (CHM) is like a step-by-step guide that ethical hackers follow to find and fix security weaknesses in computer systems, similar to a detective using a specific process to solve a mystery.



Cyber Kill Chain Methodology

The Cyber Kill Chain Methodology is like understanding the stages an attacker goes through to carry out a cyberattack, is like breaking down a cyberattack into different stages, from the initial intrusion (like a thief breaking into a house) to the final goal (like stealing valuable information), helping defenders understand and stop the attack at various points in the process.

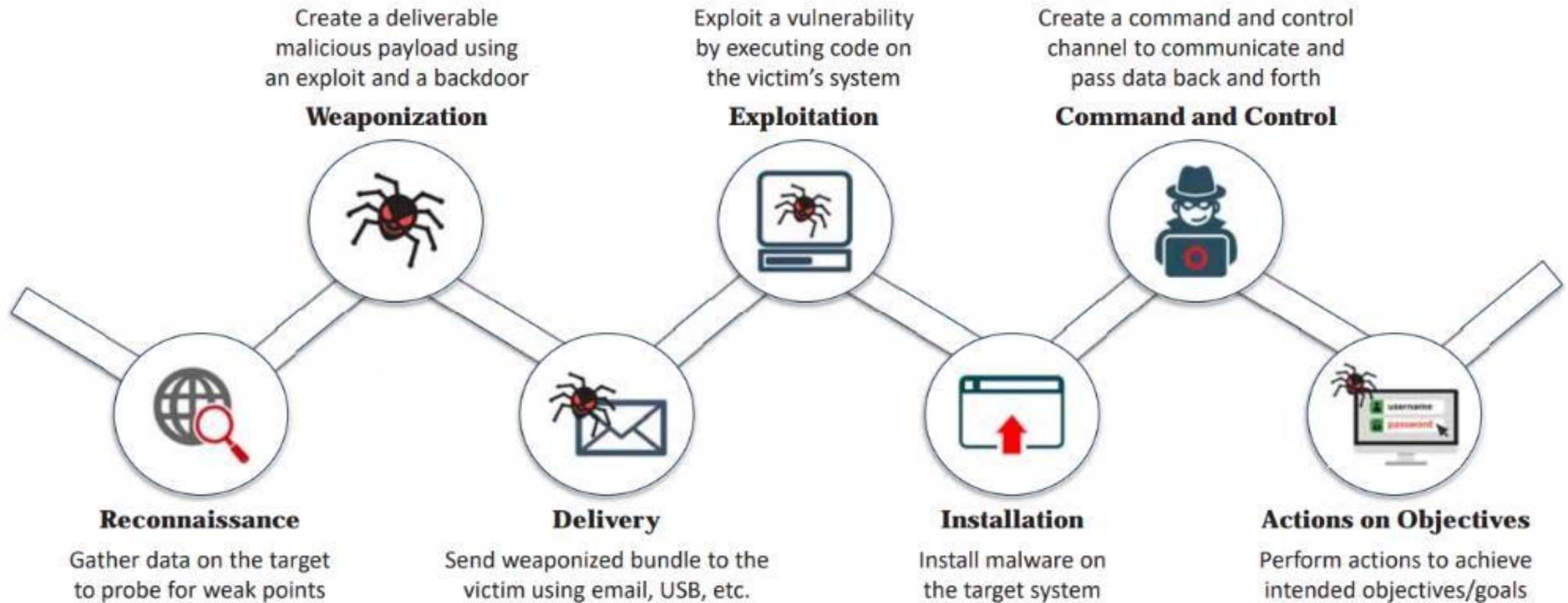
- The cyber kill chain methodology is a component of intelligence-driven defense for the identification and **prevention of malicious intrusion activities**
- It provides greater insight into attack phases, which helps security professionals to understand the **adversary's tactics, techniques, and procedures beforehand**



Cyber Kill Chain Methodology (Contd.)



Cyber Kill Chain Methodology (Contd.)



Tactics, Techniques, and Procedures (TTPs):

The term Tactics, Techniques, and Procedures (TTPs) refers to the **patterns of activities and methods** associated with specific threat actors or groups of threat actors

Tactics

- “Tactics” are the guidelines that describe the **way an attacker performs the attack** from beginning to the end
- This guideline consists of the various **tactics for information gathering** to perform initial exploitation, privilege escalation, and lateral movement, and to deploy measures for persistent access to the system and other purposes

Techniques

- “Techniques” are the **technical methods used by an attacker** to achieve intermediate results during the attack
- These techniques include **initial exploitation**, setting up and maintaining **command and control channels**, accessing the target infrastructure, covering the tracks of data exfiltration, and others

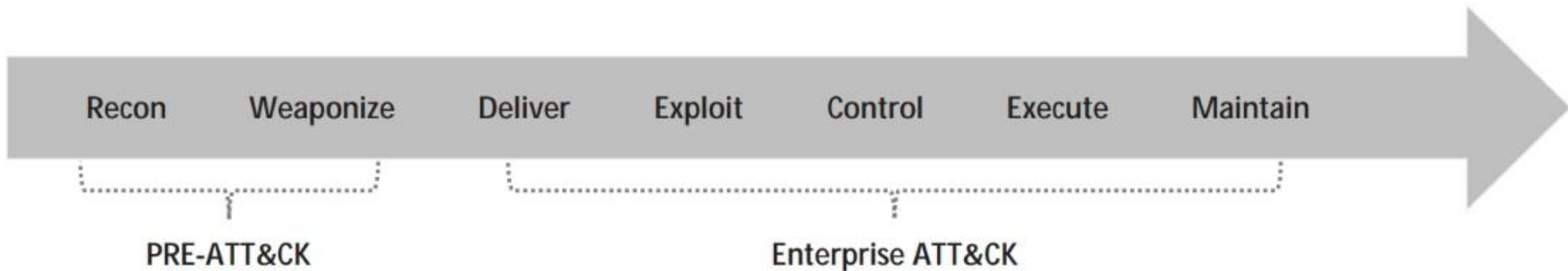
Procedures

- “Procedures” are **organizational approaches that threat actors follow** to launch an attack
- The number of **actions usually differs** depending on the objectives of the procedure and threat actor group



MITRE ATT&CK Framework

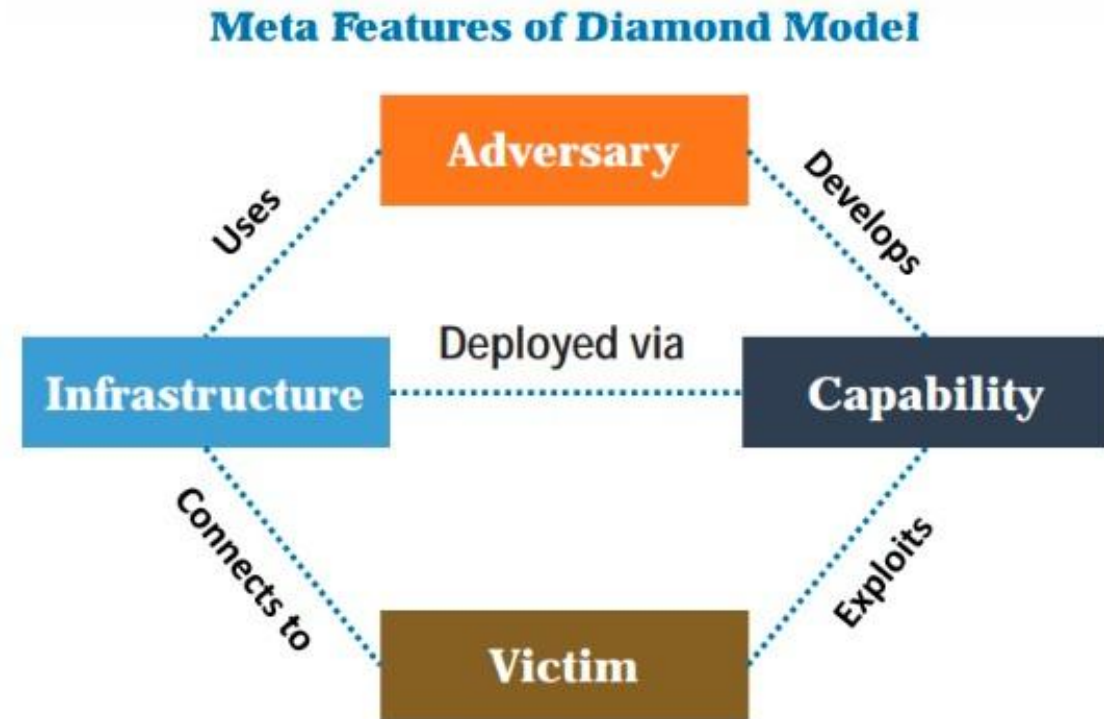
- 1** MITRE ATT&CK is a globally accessible knowledge base of **adversary tactics and techniques** based on real-world observations
- 2** The ATT&CK knowledge base is used as a foundation for the development of specific **threat models** and methodologies in the private sector, **government**, and the **cybersecurity product** and service community
- 3** The 14 tactic categories within ATT&CK for Enterprise are derived from the later stages (exploit, control, maintain, and execute) of the seven stages of the **Cyber Kill Chain**



Diamond Model of Intrusion Analysis

The Diamond Model of Intrusion Analysis is like a tool that helps cybersecurity professionals investigate cyberattacks by examining four key elements: **adversary**, **infrastructure**, **capability**, and **victim**, similar to detectives studying clues, motives, and suspects to solve a crime.

Adversary	An opponent “ who ” was behind the attack
Infrastructure	“ what ” the adversary used to reach the victim
Capability	The attack strategies or “ how ” the attack was performed
Victim	The target that has been exploited or “ where ” the attack was performed





Hacking Concepts and Different Hacker Classes

What is Hacking?

- Hacking is like finding a hidden backdoor to a building or finding a clever way to open a locked door, but in the digital world, where people use their computer skills to access information or systems without permission, like trying to unlock a door without the owner's knowledge.



Who is a Hacker?

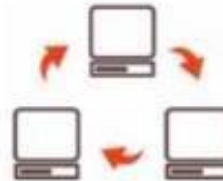
01

An intelligent individual with **excellent computer skills** who can create and explore computer software and hardware



02

For some hackers, **hacking is a hobby** to see how many computers or networks they can compromise



03

Some hackers' intentions can either be to gain knowledge or to **probe and do illegal things**



Some hack with **malicious intent** such as to steal business data, credit card information, social security numbers, email passwords, and other sensitive data

Hacker Classes

01

Black Hats

Individuals with extraordinary computing skills; they resort to malicious or destructive activities and are also known as crackers

02

White Hats

Individuals who use their professed hacking skills for defensive purposes and are also known as security analysts. They have permission from the system owner

03

Gray Hats

Individuals who work both offensively and defensively at various times

04

Suicide Hackers

Individuals who aim to bring down the critical infrastructure for a "cause" and are not worried about facing jail terms or any other kind of punishment

05

Script Kiddies

An unskilled hacker who compromises a system by running scripts, tools, and software that were developed by real hackers

06

Cyber Terrorists

Individuals with wide range of skills who are motivated by religious or political beliefs to create fear through the large-scale disruption of computer networks

07

State-Sponsored Hackers

Individuals employed by the government to penetrate and gain top-secret information from and do damage to the information systems of other governments

08

Hacktivist

Individuals who promote a political agenda by hacking, especially by using hacking to deface or disable website

Hacker Classes (Contd.)

09

Hacker Teams

A consortium of skilled hackers having their own resources and funding. They work together in synergy for researching the state-of-the-art technologies

10

Industrial Spies

Individuals who perform corporate espionage by illegally spying on competitor organizations and focus on stealing information such as blueprints and formulas

11

Insider

Any trusted person who has access to critical assets of an organization. They use privileged access to violate rules or intentionally cause harm to the organization's information system

12

Criminal Syndicates

Groups of individuals that are involved in organized, planned, and prolonged criminal activities. They illegally embezzle money by performing sophisticated cyber-attacks

13

Organized Hackers

Miscreants or hardened criminals who use rented devices or botnets to perform various cyber-attacks to pilfer money from victims

Ethical Hacking Concepts and Scope

A glowing green padlock icon is centered over a background of circuitry and data points. The padlock is a simple, stylized shape with a rectangular body and a circular shackle. It has a bright green glow and is surrounded by a faint, circular pattern of small, glowing green dots. The background is a dark, textured surface with a complex network of white and yellow lines, resembling a circuit board or a data map. The overall aesthetic is high-tech and digital.

What is Ethical Hacking?

- ***Ethical hacking*** is like being a good guy detective in the digital world, where you use your computer skills to find and fix security weaknesses in systems and networks, helping protect them from bad-guy hackers, similar to a security consultant who tests a building's locks to make sure they can't be easily broken.



Why Ethical Hacking is Necessary

Ethical hacking is necessary because it helps organizations discover and fix vulnerabilities in their computer systems before malicious hackers can exploit them, just like checking your home's locks to prevent burglaries.

To beat a hacker, you need to think like one!

Ethical hacking is necessary as it **allows for counter attacks against malicious hackers** through anticipating the methods used to break into the system

Reasons why organizations recruit ethical hackers

To **prevent hackers** from gaining access to the organization's information systems

To provide adequate preventive measures in order to **avoid security breaches**

To **uncover vulnerabilities** in systems and explore their potential as a security risk

To help **safeguard customer data**

To analyze and **strengthen an organization's security posture**, including policies, network protection infrastructure, and end-user practices

To **enhance security awareness** at all levels in a business

Why Ethical Hacking is Necessary (Contd.)

Ethical Hackers Try to Answer the Following Questions

- 1 What can an intruder see on the **target system**? (Reconnaissance and Scanning phases)
- 2 What can an **intruder do** with that information? (Gaining Access and Maintaining Access phases)
- 3 Does anyone at the target organization **notice the intruders' attempts** or successes? (Reconnaissance and Covering Tracks phases)
- 4 Are all **components of the information system** adequately protected, updated, and patched?
- 5 How much time, effort, and money are required to obtain **adequate protection**?
- 6 Are the **information security measures** in compliance with legal and industry standards?

Scope and Limitations of Ethical Hacking

Scope

- Ethical hacking is a crucial component of **risk assessment**, **auditing**, **counter fraud**, and information systems security **best practices**
- It is used to **identify risks** and highlight **remedial actions**. It also reduces ICT costs by resolving vulnerabilities



Limitations

- Unless the businesses already know what they are looking for and why they are **hiring an outside vendor to hack systems** in the first place, chances are there would not be much to gain from the experience
- An ethical hacker can only help the organization to better **understand its security system**; it is up to the organization to **place the right safeguards** on the network



Skills of an Ethical Hacker

1

Technical Skills

- In-depth **knowledge of major operating environments** such as Windows, Unix, Linux, and Macintosh
- In-depth **knowledge of networking** concepts, technologies, and related hardware and software
- A **computer expert** adept at technical domains
- **Knowledgeable about security areas** and related issues
- **“High technical” knowledge** for launching sophisticated attacks

2

Non-Technical Skills

- The **ability to learn** and adopt new technologies quickly
- **Strong work ethics** and good problem solving and communication skills
- Committed to the **organization's security policies**
- An awareness of **local standards and laws**



Techniques used in Information Security Controls



Information Assurance (IA)

Information Assurance (IA) is like having strong security measures in place to ensure that your sensitive data, like personal information or company secrets, is protected from unauthorized access or theft, similar to using a locked safe to keep your valuable items secure.

■ IA refers to the assurance that the **integrity, availability, confidentiality**, and **authenticity** of information and information systems is protected during the usage, processing, storage, and transmission of information

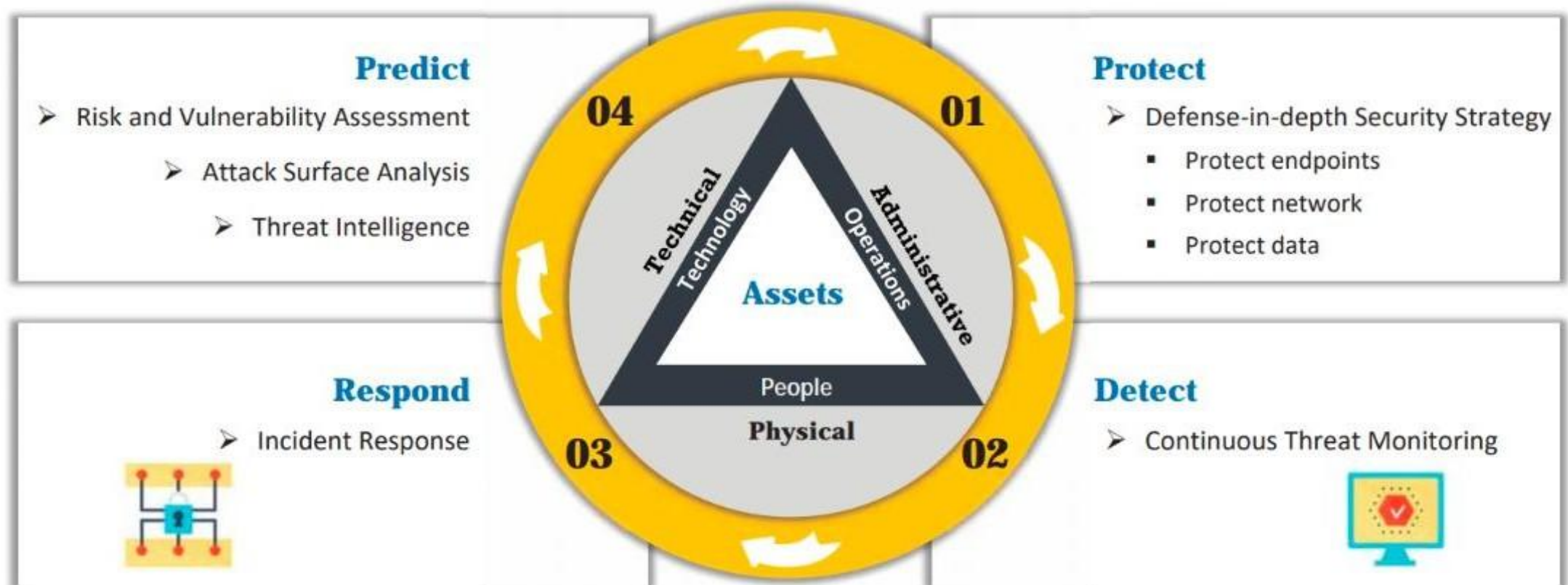
■ Some of the processes that help in achieving information assurance include:

- 1 Developing local policy, process, and guidance
- 2 Designing network and user authentication strategies
- 3 Identifying network vulnerabilities and threats
- 4 Identifying problem and resource requirements
- 5 Creating plans for identified resource requirements
- 6 Applying appropriate information assurance controls
- 7 Performing certification and accreditation
- 8 Providing information assurance training

Continual/Adaptive Security Strategy

A continual/adaptive security strategy is like regularly updating your home security measures and alarm system to stay ahead of new threats and vulnerabilities, similar to installing better locks and security cameras when you hear about new burglary techniques.

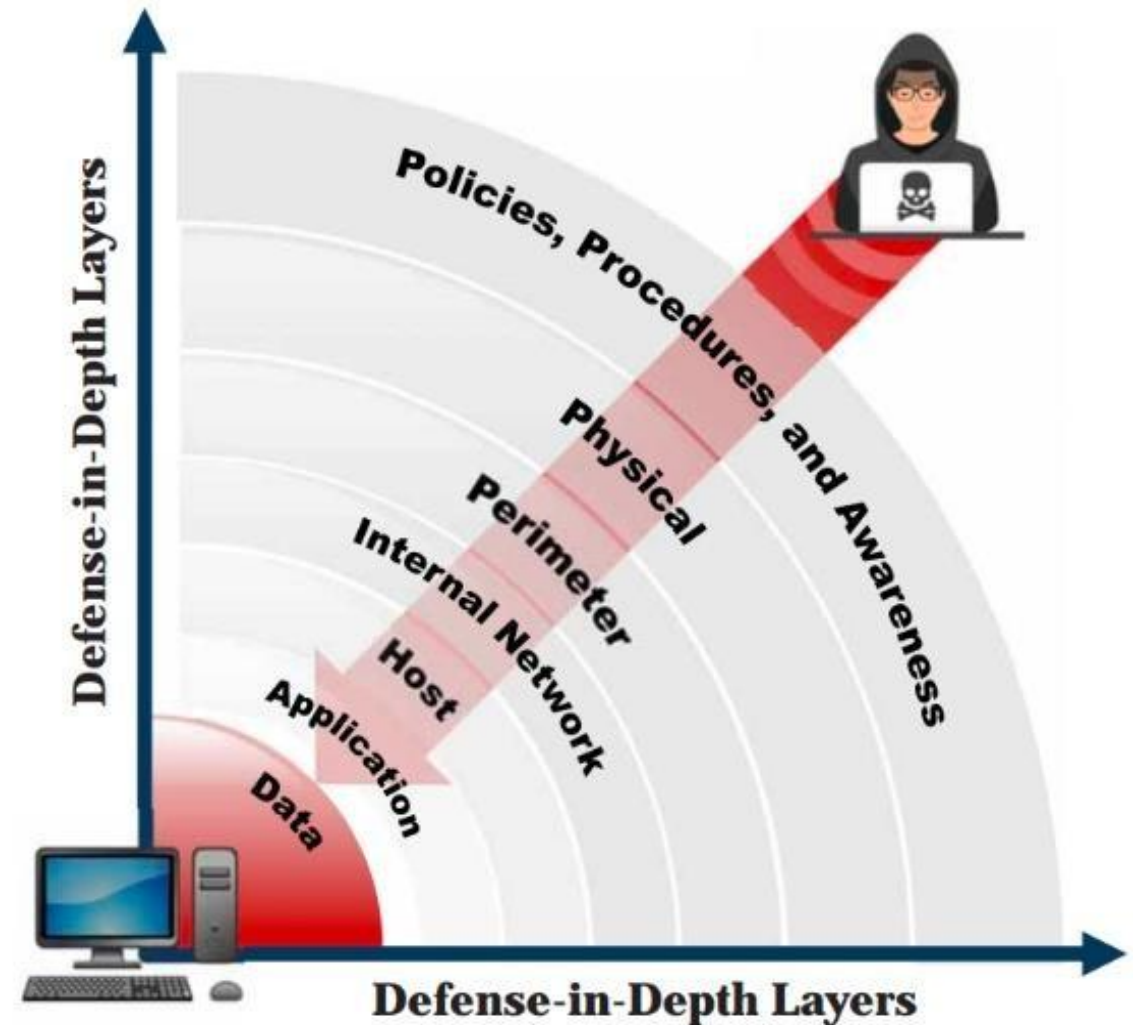
It is an iterative and proactive approach to security that emphasizes continuous monitoring, assessment, and adjustment of security measures to effectively address evolving threats and vulnerabilities.



Defense-in-Depth

Defense-in-depth is like having multiple layers of security around your home, including locks, an alarm system, and a fence, so even if one layer fails, there are other barriers in place to protect your property.

- Defense-in-depth is a security strategy in which **several protection layers** are placed throughout an information system
- It helps to **prevent direct attacks** against the system and its data because a break in one layer only leads the attacker to the next layer



What is Risk?

Risk is like the chance of something bad happening in the future, such as your phone getting stolen when you leave it unattended in a public place.

- Risk refers to the degree of **uncertainty** or expectation that an adverse event may cause damage to the system
- Risks are categorized into different levels according to their estimated impact on the system
- A risk matrix is used to scale risk by considering the **probability, likelihood**, and **consequence or impact** of the risk

Risk Levels

Risk Level	Action
Extreme or High	➤ Immediate measures should be taken to combat risk ➤ Identify and impose controls to reduce risk to a reasonably low level
Medium	➤ No urgent action is required ➤ Implement controls as soon as possible to reduce risk to a reasonably low level
Low	➤ Take preventive steps to mitigate the effects of risk

Risk Matrix

Probability		Consequences				
		Insignificant	Minor	Moderate	Major	Severe
81 - 100%	Likelihood	Very High Probability	Low	Medium	High	Extreme
61 - 80%		High Probability	Low	Medium	High	Extreme
41 - 60%		Equal Probability	Low	Medium	High	High
21 - 40%		Low Probability	Low	Low	Medium	High
1 - 20%		Very Low Probability	Low	Low	Medium	High

Note: This is an example of a risk matrix. Organizations need to create their own risk matrix based on their business needs

Risk vs Threat

- Risk is like the chance of getting into a car accident when driving, while a threat is like a specific danger that increases the risk, such as a reckless driver on the road.
- In cybersecurity, risk refers to the potential harm or damage that can occur to a computer system, network, or data, while a threat is a specific event or action that could exploit vulnerabilities in the system and lead to potential risks.
- For example, the risk in cybersecurity might be the possibility of a data breach, while a threat could be a hacker attempting to exploit a software vulnerability to gain unauthorized access to sensitive information, thereby increasing the risk of a data breach occurring.

Risk management

Risk management is like making a plan to protect your computer from viruses by installing antivirus software, regularly updating it, and being cautious about the websites you visit to reduce the chances of a cyberattack.

- Risk management is the process of **reducing and maintaining risk at an acceptable level** by means of a well-defined and actively employed security program

Risk Management Phases

Risk Identification

- **Identifies the sources**, causes, consequences, and other details of the internal and external risks affecting the security of the organization

Risk Assessment

- **Assesses the organization's risk** and provides an estimate of the likelihood and impact of the risk

Risk Treatment

- **Selects and implements appropriate controls** for the identified risks

Risk Tracking

- **Ensures appropriate controls are implemented** to handle known risks and calculates the chances of a new risk occurring

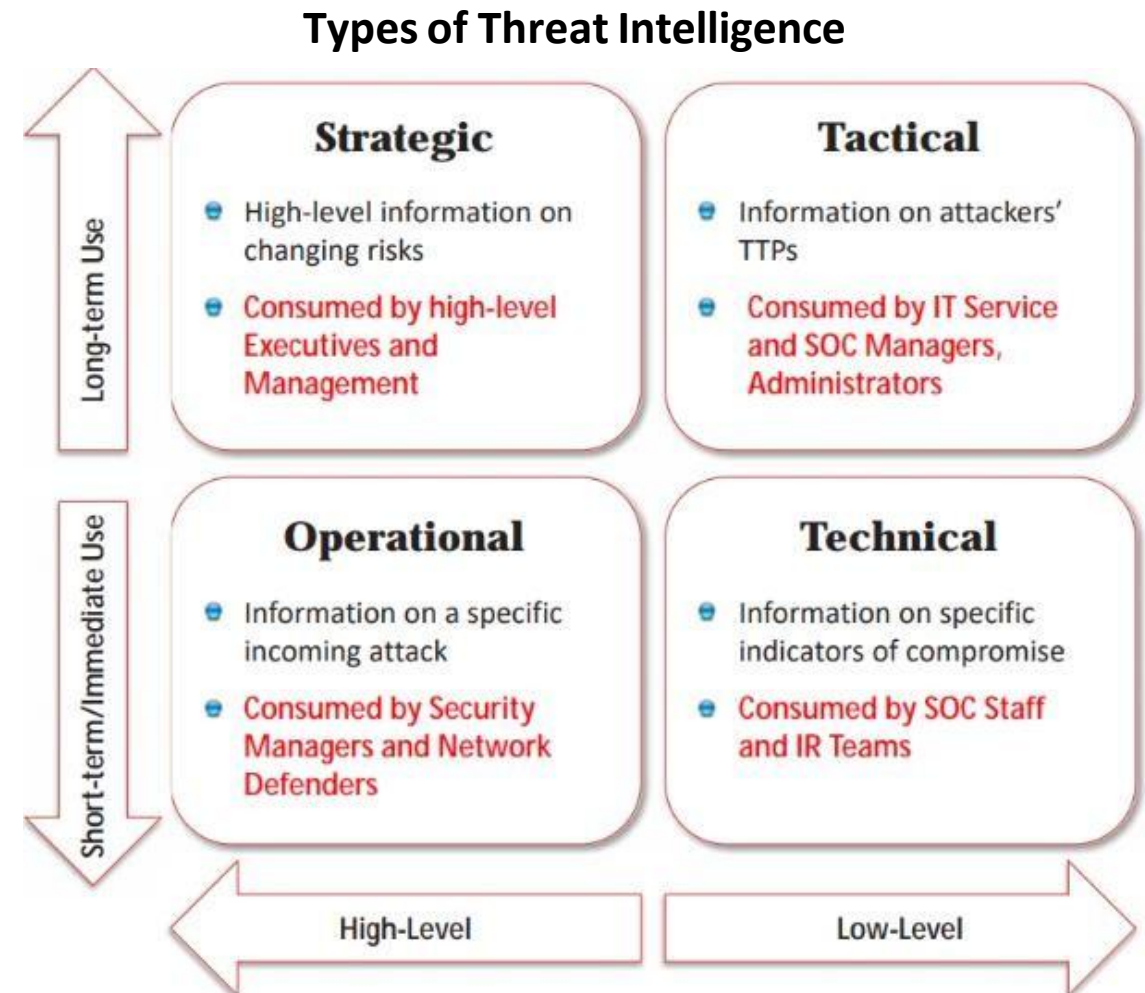
Risk Review

- **Evaluates the performance** of the implemented risk management strategies

Cyber Threat Intelligence

Cyber Threat Intelligence is like having a spy who gathers information about potential cyberattacks, such as who might attack, how they might do it, and what their targets are, helping you prepare and defend your digital assets, just like a detective collecting clues to prevent a crime.

- Cyber Threat Intelligence (CTI) is defined as the **collection and analysis of information** about threats and adversaries and the drawing of patterns that provide the ability to make knowledgeable decisions for preparedness, prevention, and response actions against various cyber-attacks
- Cyber threat intelligence helps the organization to **identify and mitigate various business risks** by converting unknown threats into known threats; it helps in implementing various advanced and proactive defense strategies



Threat Intelligence Lifecycle

5. Dissemination and Integration

- Deliver the intelligence to the intended consumers at different levels
 - Strategic (High-Level Business Strategies)
 - Tactical (TTPs)
 - Operational (Specific Threats)
 - Technical (IoCs)

4. Analysis and Production

- Combine information from phase 3 into a single entity
- Include facts, findings, and forecasts
- Analysis should be
 - Objective
 - Timely
 - Accurate
 - Actionable
- Perform confidence-based analysis



1. Planning and Direction

- Define intelligence requirements
- Make a collection plan
- Form an intelligence team
- Send requests for data collection
- Plan and set requirements for other phases

2. Collection

- Collect required data that satisfies intelligence goals
- Collection sources include
 - OSINT
 - HUMINT
 - IMINT
 - MASINT, etc.

3. Processing and Exploitation

- Process raw data for exploitation
- Convert processed data into usable format for data analysis

Threat Modeling

Threat modeling is like creating a map that shows all the possible ways a thief could break into your house, helping you strengthen security in those vulnerable areas, similar to planning to install better locks and security cameras where they're needed most.

Threat modeling is a **risk assessment approach** for analyzing the security of an application by capturing, organizing, and analyzing all the information that affects the security of an application

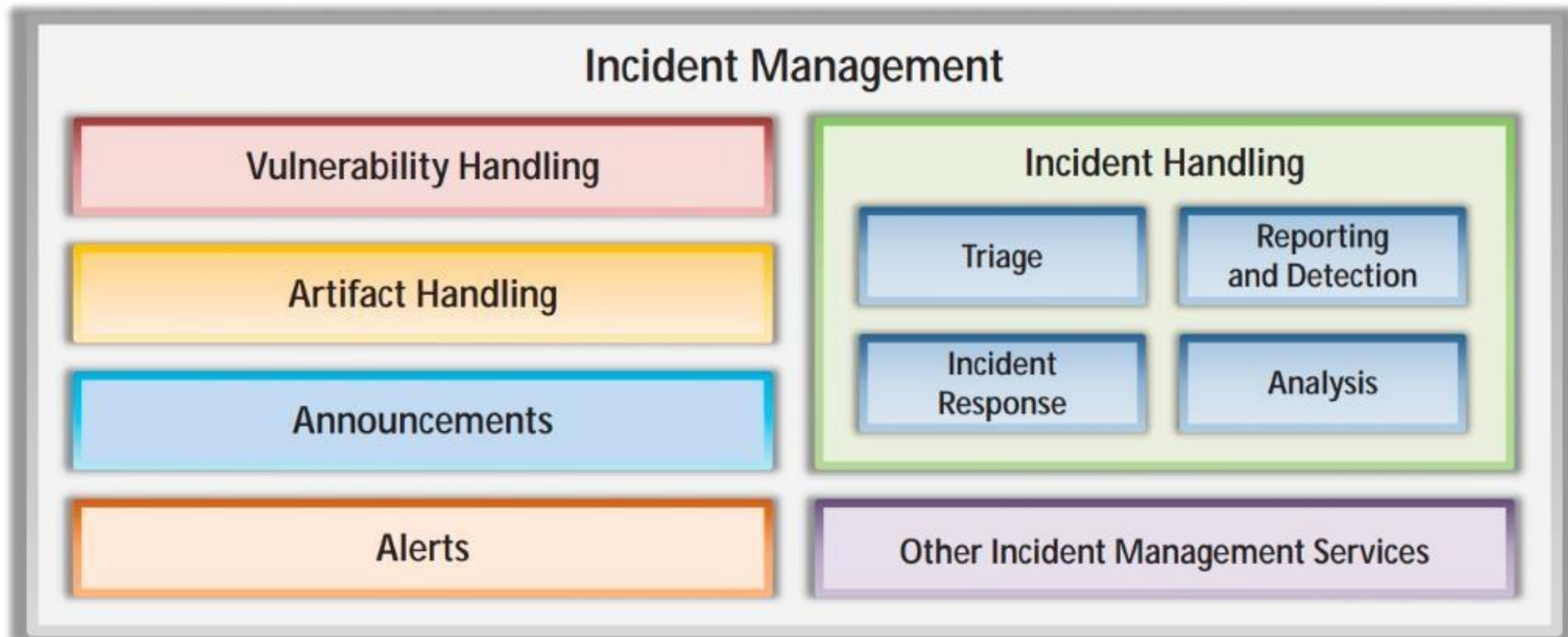
Threat Modeling Process

01	Identify Security Objectives	Helps to determine how much effort needs to be put toward subsequent steps
02	Application Overview	Identify the components, data flows , and trust boundaries
03	Decompose the Application	Helps to find more relevant and more detailed threats
04	Identify Threats	Identify threats relevant to the control scenario and context using the information obtained in steps 2 and 3
05	Identify Vulnerabilities	Identify weaknesses related to the threats found using vulnerability categories

Incident Management

Incident management is like having a fire brigade for cybersecurity, where trained professionals respond swiftly to cyberattacks or breaches, containing the damage and restoring normal operations, just like firefighters extinguish fires and save lives during emergencies.

- Incident management is a set of defined processes to **identify, analyze, prioritize, and resolve security incidents** to restore normal service operations as quickly as possible and prevent future recurrence of the incident



Incident Handling and Response

Incident handling and response is like having a well-drilled emergency team for cybersecurity, ready to detect, assess, and effectively react to any cyber incident, ensuring a rapid and coordinated effort to minimize damage and protect systems and data.

Steps involved in the IH&R process:

1 Preparation

2 Incident Recording and Assignment

3 Incident Triage

4 Notification

5 Containment

6 Evidence Gathering and Forensic Analysis

7 Eradication

8 Recovery

9 Post-Incident Activities

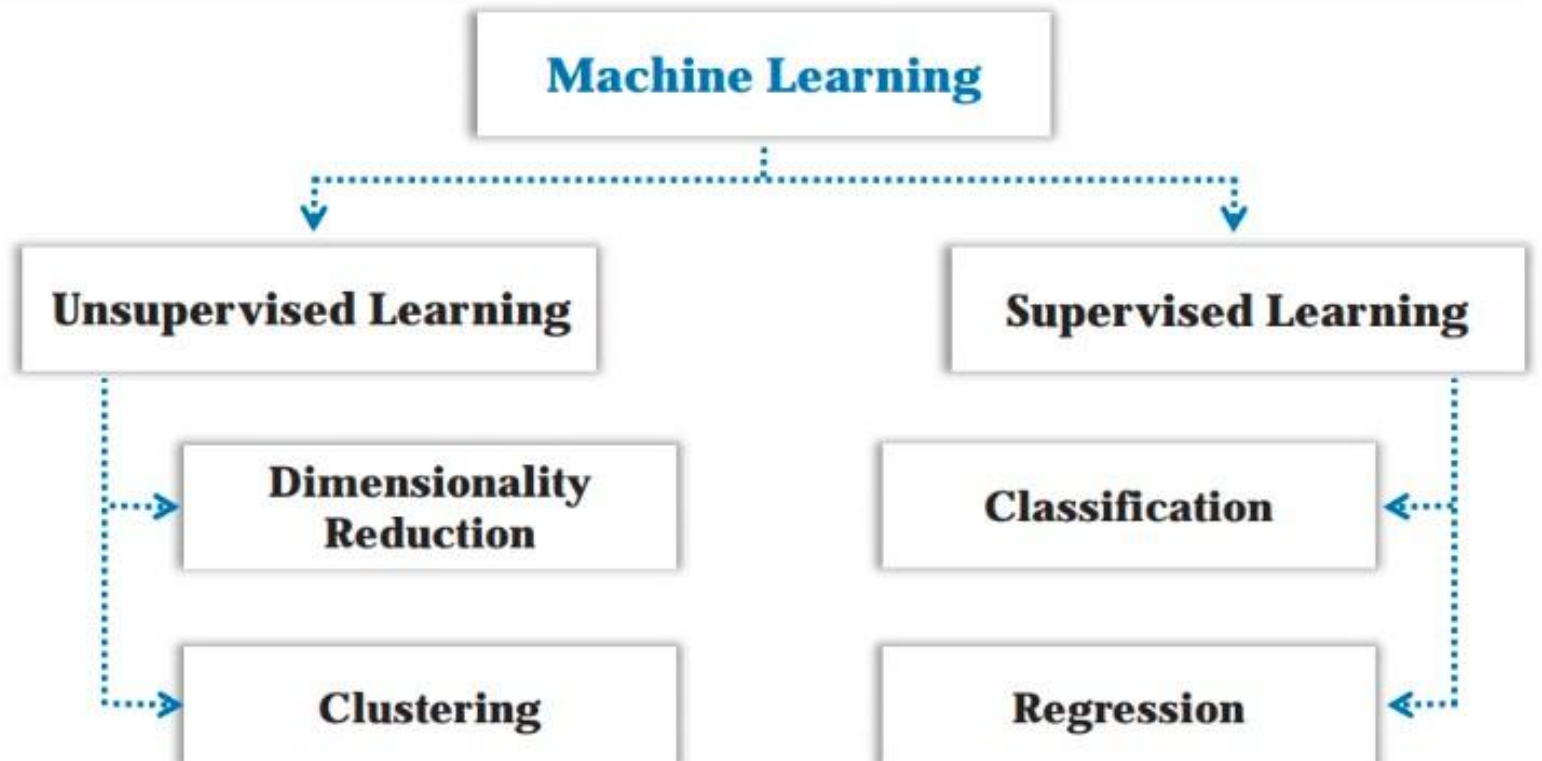
- Incident Documentation
- Incident Impact Assessment
- Review and Revise Policies
- Close the Investigation
- Incident Disclosure

Role of AI and ML in Cyber Security

- Machine learning (ML) and artificial intelligence (AI) are now vastly used across various industries and applications due to the **increase in computing power, data collection, and storage capabilities**
- ML is an **unsupervised self-learning system** that is used to define what the normal network looks like, along with its devices, and then to backtrack and **report any deviations or anomalies** in real-time
- AI and ML in cyber security helps in **identifying new exploits and weaknesses**, which can then be easily analyzed to mitigate further attacks

ML classification techniques:

- Supervised learning makes use of algorithms that input a **set of labeled training data**, with the aim of learning the differences between the labels
- Unsupervised learning makes use of algorithms that input **unlabeled training data**, with the aim of deducing all categories by itself



How Do AI and ML Prevent Cyber Attacks?

1

Password Protection and Authentication

2

Phishing Detection and Prevention

3

Threat Detection

4

Vulnerability Management

5

Behavioral Analytics

6

Network Security

7

AI-based Antivirus

8

Fraud Detection

9

Botnet Detection

10

AI to Combat AI Threats

Importance of Applicable Security Laws and Standards



The Payment Card Industry Data Security Standard (PCI DSS)

The Payment Card Industry Data Security Standard (PCI DSS) is a specific set of security rules designed for organizations that deal with cardholder information from various types of cards, like debit, credit, prepaid, e-purse, ATM, and point-of-sale (POS) cards. PCI DSS is applicable to all parties involved in payment card processing, such as merchants, processors, acquirers, issuers, service providers, and any other entities responsible for storing, processing, or transmitting cardholder data. It is designed to protect against cardholder data breaches. Failure to meet the PCI DSS requirements may result in fines or the termination of payment card processing privileges .



PCI Data Security Standard — High Level Overview

Build and Maintain a Secure Network

Protect Cardholder Data

Maintain a Vulnerability Management Program

Implement Strong Access Control Measures

Regularly Monitor and Test Networks

Maintain an Information Security Policy

ISO/IEC 27001:2013

ISO/IEC 27001:2013 is an international standard that sets out the criteria for establishing, implementing, maintaining, and continually improving an information security management system (ISMS) within the context of the organization's overall business risks.



1

Use within organizations to formulate **security requirements** and **objectives**

2

Use within organizations to ensure that security risks are **cost-effectively managed**

3

Use within organizations to **ensure compliance with laws and regulations**

4

Definition of new **information security management processes**

5

Identification and clarification of existing **information security management processes**

6

Use by organization management to determine the **status of information security management activities**

7

Implementation of **business-enabling information security**

8

Use by organizations to provide relevant information about **information security** to customers

Health Insurance Portability and Accountability Act (HIPAA)

The Health Insurance Portability and Accountability Act (HIPAA) is a United States federal law that aims to safeguard individuals' protected health information (PHI) by establishing rules and standards for the secure handling, storage, and sharing of this sensitive data in the healthcare industry.



Electronic Transaction and Code Set Standards

Requires every provider who does business electronically to **use the same health care transactions, code sets, and identifiers**

Privacy Rule

Provides **federal protections for the personal health information** held by covered entities and gives patients an array of rights with respect to that information

Security Rule

Specifies a series of administrative, physical, and technical safeguards for covered entities to use to ensure the **confidentiality, integrity, and availability of electronically protected health information**

National Identifier Requirements

Requires that health care providers, health plans, and employers have standard national numbers that identify them attached to **standard transactions**

Enforcement Rule

Provides the standards for enforcing all the **Administration Simplification Rules**

Sarbanes Oxley Act (SOX)

The Sarbanes-Oxley Act (SOX) is a United States federal law passed in 2002 that aims to protect investors and the public from fraudulent financial practices by setting requirements for financial reporting, corporate governance, and the responsibilities of public company boards and auditors.



Title I	Public Company Accounting Oversight Board (PCAOB)	Title VI	Commission Resources and Authority
Title II	Auditor Independence	Title VII	Studies and Reports
Title III	Corporate Responsibility	Title VIII	Corporate and Criminal Fraud Accountability
Title IV	Enhanced Financial Disclosures	Title IX	White Collar Crime Penalty Enhancement
Title V	Analyst Conflicts of Interest	Title X	Corporate Tax Returns
Title XI	Corporate Fraud Accountability		

The Digital Millennium Copyright Act (DMCA)

The Digital Millennium Copyright Act (DMCA) is a U.S. legislation that addresses copyright infringement related to digital content and provides provisions for takedown notices and safe harbors for online service providers.

The Digital Millennium Copyright Act (DMCA)

- The DMCA is a United States copyright law that implements two 1996 treaties of the **World Intellectual Property Organization** (WIPO)
- It **defines the legal prohibitions** against the circumvention of technological protection measures employed by copyright owners to protect their works, and against the removal or alteration of copyright management information



Federal Information Security Management Act (FISMA)

The Federal Information Security Management Act (FISMA) is a U.S. law that establishes a framework for securing federal government information systems by requiring agencies to develop, implement, and maintain comprehensive security programs and practices.

- The FISMA provides a comprehensive framework for ensuring the **effectiveness of information security controls** over information resources that support Federal operations and assets
- It includes
 - Standards for categorizing information and information systems by mission impact
 - Standards for minimum security requirements for information and information systems
 - Guidance for selecting appropriate security controls for information systems
 - Guidance for assessing security controls in information systems and determining security control effectiveness
 - Guidance for security authorization of information systems

<https://csrc.nist.gov>



General Data Protection Regulation (GDPR)

The General Data Protection Regulation (GDPR) is a European Union regulation that aims to protect the privacy and personal data of EU citizens by setting strict requirements for data collection, processing, storage, and consent by organizations.



GDPR Data Protection Principles

- **Lawfulness, fairness, and transparency:** Processing must be lawful, fair, and transparent to the data subject
- **Purpose limitation:** You must process data for the legitimate purposes specified explicitly to the data subject when you collected it
- **Data minimization:** You should collect and process only as much data as necessary for the purposes specified
- **Accuracy:** You must keep personal data accurate and up to date
- **Storage limitation:** You may only store personally identifying data for as long as necessary for the specified purpose
- **Integrity and confidentiality:** Processing must be done in such a way as to ensure appropriate security, integrity, and confidentiality (e.g., by using encryption)
- **Accountability:** The data controller is responsible for demonstrating GDPR compliance with all these principles

Data Protection Act 2018 (DPA)

The Data Protection Act 2018 (DPA) is a UK legislation that governs the processing and protection of personal data, providing individuals with rights and organizations with responsibilities for handling and managing personal information.



Data Protection Act 2018

- The **DPA 2018** sets out the framework for data protection law in the **UK**

- It **updates** and **replaces** the Data Protection Act 1998 and came into effect on 25 May, 2018

- The DPA is an act to make provision for the regulation of the processing of information relating to **individuals**; to make provision in connection with the **Information Commissioner's functions** under specific regulations relating to information; to make provision for a direct **marketing code** of practice, and connected purposes

- The DPA **protects individuals** concerning the processing of personal data, in particular by:

- Requiring **personal data to be processed lawfully** and fairly, based on the data subject's consent or another specified basis,
- **Conferring rights** on the data subject to obtain information about the processing of personal data and to require inaccurate personal data to be rectified, and
- **Conferring functions** on the Commissioner, giving the holder of that office responsibility to monitor and enforce their provisions

Cyber Law in Different Countries

- *Cyber laws vary from country to country*, but their importance during ethical hacking can be summarized as follows:
- **Legal Compliance:** Ethical hackers need to operate within the boundaries of the law. Understanding the cyber laws of a specific country helps ensure that ethical hacking activities are conducted in compliance with legal requirements and avoid any potential legal consequences.



Cyber Law in Different Countries (Contd.)

- **Authorization and Consent:** Cyber laws define the scope and boundaries of authorized hacking activities. Ethical hackers must obtain proper authorization and informed consent from relevant parties before performing any hacking or penetration testing activities to ensure they are operating within the legal framework.



Cyber Law in Different Countries (Contd.)

- **Liability and Responsibility:** Cyber laws establish liability and responsibility for hacking activities. Understanding these laws helps ethical hackers mitigate legal risks and protect themselves from potential liability for unintentional damage or data breaches that may occur during their activities.





Cyber Law in Different Countries (Contd.)

- **Protection of Privacy and Data:** Cyber laws often include provisions for protecting privacy and personal data. Ethical hackers need to respect and uphold these laws while conducting their activities to ensure the privacy rights of individuals and the security of sensitive information are preserved.



Cyber Law in Different Countries (Contd.)

- **Ethical Boundaries:** Cyber laws help define the ethical boundaries and acceptable conduct for hacking activities. Adhering to these laws ensures that ethical hackers maintain a code of ethics and do not engage in any malicious or unlawful activities that could harm individuals or organizations.



Cyber Law in Different Countries (Contd.)

- **Collaboration with Law Enforcement:** Cyber laws provide a legal framework for ethical hackers to collaborate with law enforcement agencies when necessary. Understanding the laws helps ethical hackers navigate the process of reporting and cooperating with authorities in case they come across illegal activities or evidence during their hacking engagements.

Cyber Law in Different Countries (Contd.)

Country Name	Laws/Acts	Website
United States	Section 107 of the Copyright Law mentions the doctrine of “fair use”	https://www.copyright.gov
	Online Copyright Infringement Liability Limitation Act	
	The Lanham (Trademark) Act (15 USC §§ 1051 - 1127)	https://www.uspto.gov
	The Electronic Communications Privacy Act	https://fas.org
	Foreign Intelligence Surveillance Act	https://fas.org
	Protect America Act of 2007	https://www.justice.gov
	Privacy Act of 1974	https://www.justice.gov
	National Information Infrastructure Protection Act of 1996	https://www.congress.gov
	Computer Security Act of 1987	https://csrc.nist.gov
	Freedom of Information Act (FOIA)	https://www.foia.gov
	Computer Fraud and Abuse Act	https://energy.gov
	Federal Identity Theft and Assumption Deterrence Act	https://www.ftc.gov

Cyber Law in Different Countries (Contd.)

Country Name	Laws/Acts	Website
Australia	The Trade Marks Act 1995	https://www.legislation.gov.au
	The Patents Act 1990	
	The Copyright Act 1968	
	Cybercrime Act 2001	
United Kingdom	The Copyright, Etc. and Trademarks (Offenses And Enforcement) Act 2002	https://www.legislation.gov.uk
	Trademarks Act 1994 (TMA)	
	Computer Misuse Act 1990	
	The Network and Information Systems Regulations 2018	
	Communications Act 2003	
	The Privacy and Electronic Communications (EC Directive) Regulations 2003	
	Investigatory Powers Act 2016	
	Regulation of Investigatory Powers Act 2000	
China	Copyright Law of the People's Republic of China (Amendments on October 27, 2001)	http://www.npc.gov.cn
	Trademark Law of the People's Republic of China (Amendments on October 27, 2001)	
India	The Patents (Amendment) Act, 1999, Trade Marks Act, 1999, The Copyright Act, 1957	http://www.ipindia.nic.in
	Information Technology Act	https://www.meity.gov.in
Germany	Section 202a. Data Espionage, Section 303a. Alteration of Data, Section 303b. Computer Sabotage	https://www.cybercrimelaw.net

Cyber Law in Different Countries (Contd.)

Country Name	Laws/Acts	Website
Italy	Penal Code Article 615 ter	https://www.cybercrimelaw.net
Japan	The Trademark Law (Law No. 127 of 1957), Copyright Management Business Law (4.2.2.3 of 2000)	https://www.iip.or.jp
Canada	Copyright Act (R.S.C., 1985, c. C-42), Trademark Law, Canadian Criminal Code Section 342.1	https://laws-lois.justice.gc.ca
Singapore	Computer Misuse Act	https://sso.agc.gov.sg
South Africa	Trademarks Act 194 of 1993	http://www.cipc.co.za
	Copyright Act of 1978	https://www.nlsa.ac.za
South Korea	Copyright Law Act No. 3916	https://www.copyright.or.kr
	Industrial Design Protection Act	https://www.kipo.go.kr
Belgium	Copyright Law, 30/06/1994	https://www.wipo.int
	Computer Hacking	https://www.cybercrimelaw.net
Brazil	Unauthorized modification or alteration of the information system	https://www.domstol.no
Hong Kong	Article 139 of the Basic Law	https://www.basiclaw.gov.hk

Module Summary



- ☐ This module discussed elements of information security, information security attacks, and information warfare
- ☐ It discussed various hacking methodologies and frameworks including CEH hacking methodology (CHM), cyber kill chain methodology, MITRE ATT&CK framework, and diamond model for intrusion analysis
- ☐ It also discussed hacking concepts and hacker classes
- ☐ This module also covered ethical hacking concepts such as the scope and limitations of ethical hacking, skills, and other pertinent information in detail
- ☐ It discussed information security controls such as defense-in-depth, risk management, cyber threat intelligence, threat modeling, incident management process, and AI and ML
- ☐ This module ended with a detailed discussion of various information security acts and laws from around the world
- ☐ The next module will go into detail about how attackers, as well as ethical hackers and pen testers, perform footprinting to collect information about the target of an evaluation before an attack or audit